DIRECTIVE SUR LA PROTECTION DE L'INFORMATION

Avis de confidentialité

Ce document contient des informations qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document, ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3
   1.1. Portée 3
   1.2. Contexte 3
   1.3. Définitions 3
2. Exigences de la directive 5
   2.1. Exigences relatives à la classification des données et de l'information 5
   2.2. Exigences relatives à la protection des données 6
   2.3. Exigences relatives à la sécurité du personnel 7
   2.4. Exigences relatives à la formation et à la sensibilisation 7
   2.5. Exigences relatives à la gestion des changements 8
   2.6. Exigences relatives à la gestion des configurations 9
   2.7. Exigences relatives à la sécurité infonuagique 9
   2.8. Exigences relatives à la cryptographie 10
   2.9. Exigences relatives à la sécurité des points de terminaison 11
   2.10. Exigences relatives à la gestion des identités et des accès 11
   2.11. Exigences relatives à la sécurité des réseaux et des communications 12
   2.12. Exigences relatives à la sécurité des opérations 13
   2.13. Exigences relatives à la sécurité physique et environnementale 13
   2.14. Exigences relatives à la gestion des sauvegardes 14
   2.15. Exigences relatives au cycle de vie du développement logiciel 15
   2.16. Exigences relatives à la sécurité des applications 15
3. Écarts et exceptions 16

Directive sur la protection de l'information	
Propriétaire	Chef de la sécurité de l'information (CISO)
Portée	Groupe
Objectif de la Directive	Établir les exigences en matière de protection des données et des informations dans l'environnement technologique de iA Groupe financier.
Date de révision	s.o.
Autorité d'approbation	Comité directeur sur la sécurité de l'information (CDSI)
Date d'approbation	7 avril 2022
Date d'entrée en vigueur	7 avril 2022
Fréquence de révision	Tous les trois (3) ans ou à la suite de changements majeurs
Prochaine révision	2025-04

1. Introduction

1.1. Portée

La *Directive sur la protection de l'information* s'applique à iA Groupe financier, à ses employés, à ses fournisseurs de services et à ses sous-traitants, consultants et toute personne dont le travail est sous la responsabilité de la direction de la Société, sur laquelle la Société exerce un contrôle direct et qui utilise les actifs de iA Groupe financier.

1.2. Contexte

La Société doit définir et mettre en œuvre des processus et des procédures pour gérer la protection des systèmes d'information afin de soutenir sa capacité à limiter ou à contenir l'impact d'éventuels événements de sécurité sur son information et ses parties prenantes.

1.3. Définitions

« L'authentification multifactorielle » est un système d'authentification qui requiert plus d'un facteur d'authentification distinct pour une authentification réussie. L'authentification multifactorielle peut être effectuée à l'aide d'un authentificateur multifactoriel ou par une combinaison d'authentificateurs qui fournissent différents facteurs. Les trois facteurs d'authentification sont quelque chose que vous savez, quelque chose que vous avez et quelque chose que vous êtes.

La « catégorisation de sécurité » est le processus qui consiste à déterminer la catégorie de sécurité d'une information ou d'un système d'information. Les catégories de sécurité décrivent les impacts négatifs potentiels sur les opérations de l'organisation, ses actifs et les individus si l'information et les systèmes d'information de l'organisation sont compris par une perte de confidentialité, d'intégrité ou de disponibilité.

Une « configuration de base » désigne les paramètres de configuration qui constituent l'ensemble des paramètres pouvant être modifiés dans les composants matériels, logiciels ou micrologiciels du système d'information et qui affectent la posture de sécurité ou la fonctionnalité du système.

Le « Comité consultatif des changements (CAB ou CCC) » est un groupe désigné de personnes chargées d'évaluer et d'autoriser les changements informatiques tout au long du cycle de développement et de vie opérationnel d'un système d'information.

Les « comptes à haut niveau de privilège » sont des comptes attribués à des personnes qui leur permettent d'exécuter certaines fonctions liées à la sécurité que les utilisateurs ordinaires ne sont pas autorisés à exécuter.

Un « environnement de production » est un environnement où la fonctionnalité et la disponibilité doivent être assurées pour la réalisation des activités quotidiennes. C'est le contraire d'un environnement de développement ou de test.

« *iA Groupe financier* » ou « *la Société* » désigne iA la Société financière inc. et ses filiales directes et indirectes, exerçant leurs activités sous le nom iA Groupe financier.

« L'infonuagique » est un modèle permettant un accès réseau omniprésent, pratique et à la demande à un pool partagé de ressources informatiques configurables (par exemple, réseaux, serveurs, stockage, applications et services) qui peuvent être rapidement approvisionnées et libérées avec un minimum d'efforts de gestion ou d'interaction avec le fournisseur de services.

Une « information confidentielle » désigne l'information qui ne doit être communiquée ou rendue accessible qu'aux personnes et aux entités autorisées. On parlera plus spécifiquement « d'information critique » lorsqu'une information confidentielle a le potentiel de mettre en péril l'intégrité de la personne ou de l'organisation qu'elle concerne.

« L'internet des objets (IdO ou plus communément IoT) » décrit le réseau d'objets physiques qui sont équipés de capteurs, de logiciels et d'autres technologies dans le but de se connecter et d'échanger des données avec d'autres dispositifs et systèmes via l'internet.

Le « nettoyage » désigne le processus visant à supprimer l'information des supports de telle sorte que leur récupération soit impossible. Il comprend la suppression de toutes les étiquettes, marquages et journaux d'activité.

Un « point de terminaison » est un dispositif informatique qui communique dans les deux sens avec un réseau auquel il est connecté. Les exemples de points de terminaison comprennent les ordinateurs de bureau, les ordinateurs portables, les téléphones intelligents, les tablettes, les serveurs (y compris IaaS), les stations de travail, les imprimantes et les dispositifs de l'Internet des objets (IoT).

Le « principe du moindre privilège » stipule que les utilisateurs et les programmes ne doivent disposer que des privilèges nécessaires à l'accomplissement de leurs tâches.

Un « renseignement personnel » désigne toute information qui concerne un individu et qui permet de l'identifier soit directement, c'est-à-dire par la simple consultation de cette information seule, soit indirectement, c'est-à-dire par recoupement avec d'autres informations, et ce, quel que soit le support ou la forme sous laquelle cette information est accessible.

Une « sauvegarde » est une copie de fichiers et de programmes effectuée pour faciliter la récupération si nécessaire. Elle désigne également le processus de copie d'information ou d'état de traitement vers un système, un service, un dispositif ou un support redondant qui peut fournir la capacité de traitement nécessaire en cas de besoin.

La « séparation des tâches » désigne le principe de répartition des privilèges entre plusieurs personnes ou systèmes. L'objectif de la séparation des tâches est de s'assurer qu'un seul point de compromission n'a pas d'impact significatif sur la Société.

Un « système de production » est utilisé pour effectuer des activités quotidiennes dans l'environnement de production.

2. Exigences de la directive

2.1. Exigences relatives à la classification des données et de l'information

La Société doit identifier, classer, étiqueter et protéger ses données et l'information tout au long de leur cycle de vie. Cela permettra d'identifier les bons contrôles à mettre en œuvre afin d'empêcher la mauvaise manipulation de l'information, y compris les renseignements personnels de ses clients, de ses employés et des autres personnes sur lesquelles la Société détient de l'information. Les exigences nécessaires pour établir des schémas de classification de données et de catégorisation de sécurité pour renforcer la position et la capacité de la Société en matière de sécurité de l'information sont énumérées ci-dessous.

a. Classer les éléments de données issus des processus d'affaires dans une structure logique définie afin de refléter le contexte dans lequel les données sont créées et utilisées tout au long de leur cycle de vie.
b. Classer l'information en fonction de son niveau de sensibilité et de l'impact sur la Société d'une divulgation, d'une modification ou d'une destruction non autorisée.
c. Catégoriser les actifs TI en termes de confidentialité, d'intégrité et de disponibilité. Cela doit être fait en tenant compte des exigences légales et de la sensibilité à la divulgation, à la modification, à la destruction ou à l'indisponibilité non autorisées de l'information qui est stockée, traitée, manipulée ou protégée par l'actif.
d. Établir une procédure pour identifier les actifs informationnels les plus précieux en fonction de la catégorisation de sécurité et d'autres facteurs pertinents.
e. Définir et mettre en œuvre un processus d'approbation de la classification de données et de la catégorisation de sécurité.
f. Revoir régulièrement les schémas de classification de données et de catégorisation de sécurité afin que les descriptions et les exemples restent actuels et appropriés.

g. Développer et mettre en œuvre un ensemble de procédures pour l'étiquetage de l'information conformément au schéma de classification de données, en donnant des indications sur l'endroit et la manière dont les étiquettes sont attachées en fonction des types de supports.
h. Former les utilisateurs pour qu'ils soient en mesure de classifier, d'étiqueter et de traiter l'information et les actifs informationnels de manière appropriée.
i. Développer et mettre en œuvre un ensemble de procédures pour la manipulation des actifs informationnels conformément aux schémas de classification de données et de catégorisation de sécurité.

2.2. Exigences relatives à la protection des données

La Société doit appliquer une combinaison de techniques de chiffrement, de protection de l'intégrité et de prévention des pertes de données, ainsi que la formation des utilisateurs finaux pour protéger ses données. Les exigences nécessaires à la protection des données afin de prévenir l'exfiltration des données et de garantir la confidentialité et l'intégrité de l'information sont énumérées ci-dessous.

a. S'assurer que des contrôles de sécurité sont définis et mis en œuvre pour protéger les données en fonction de leur niveau de sensibilité pour chaque phase du cycle de vie des données, quels que soient leur état et leur emplacement.
b. Créer et tenir à jour un inventaire des données afin de conserver des enregistrements exacts et complets de toutes les données potentiellement stockées ou traitées.
c. Définir et mettre en œuvre une stratégie de prévention des pertes de données (DLP) couvrant les scénarios et les canaux d'exfiltration de données les plus pertinents, ainsi que des actions de remédiation ciblées.
d. Mettre en œuvre des capacités de découverte de données pour soutenir la stratégie DLP, permettant l'identification de types de données confidentielles dans des emplacements inattendus.
e. Définir et appliquer des procédures de dépersonnalisation, d'anonymisation et de dévalorisation des données permettant de se conformer aux lois applicables et de réduire les risques de divulgation non autorisée.
f. Gérer le cycle de vie de l'information conformément aux règles de conservation et de destruction de la Société.
g. Définir et mettre en œuvre des procédures d'assainissement des supports lorsque les données ne sont plus nécessaires, avant leur élimination, leur diffusion hors du contrôle de la Société ou leur diffusion en vue de leur réutilisation.
h. Utiliser des mécanismes de désinfection dont la force et l'intégrité sont proportionnelles au niveau de classification de l'information stockée sur le support.
i. S'assurer que les personnes ayant accès à l'information et aux systèmes ont une bonne connaissance de la sécurité des données grâce à un programme de formation et de sensibilisation à la sécurité.

2.3. Exigences relatives à la sécurité du personnel

La Société doit s'assurer que les employés, les contractants et le personnel tiers disposent des compétences, des connaissances et des outils nécessaires pour soutenir les valeurs de la Société et adhérer aux politiques de sécurité de l'information. Les exigences en matière de sécurité de l'information doivent être intégrées à chaque étape du cycle de vie de l'emploi, en précisant les attentes en matière de sécurité tout au long de la carrière de chaque employé. Les exigences nécessaires pour promouvoir le comportement attendu en matière de sécurité auprès de toutes les parties prenantes sont énumérées ci-dessous.

a. Élaborer et maintenir des exigences de sécurité pour la sélection, le licenciement et le transfert des employés.
b. Préciser les responsabilités en matière de sécurité de l'information dans les conditions d'emploi.
c. Attribuer une désignation de risque à tous les postes et établir des exigences de filtrage pour les personnes qui occupent ces postes, y compris la vérification des antécédents et du crédit.
d. S'assurer que toutes les personnes satisfont aux exigences de filtrage et procéder régulièrement à un nouveau filtrage des personnes.
e. Former tous les employés à la sécurité de l'information afin de leur donner les connaissances et les compétences dont ils ont besoin pour effectuer leur travail en toute sécurité.
f. Employer un processus de sanction formel pour les individus qui ne respectent pas les politiques et procédures de sécurité de l'information établies.
g. Établir un processus de licenciement d'urgence si un employé doit être licencié immédiatement.
h. Récupérer les biens de la Société, désactiver l'accès aux systèmes d'information et révoquer les informations d'identification associées aux personnes lors de la cessation d'emploi ou de contrat.
i. S'assurer que les autorisations d'accès sont modifiées au besoin et que les personnes répondent aux exigences de filtrage après un changement d'emploi.
j. Établir pour les fournisseurs tiers des exigences de sécurité équivalentes à celles prescrites pour les employés internes.

2.4. Exigences relatives à la formation et à la sensibilisation

La Société doit maintenir un programme complet et continu de formation et de sensibilisation à la sécurité, afin de promouvoir et d'ancrer le comportement attendu en matière de sécurité chez toutes les personnes qui ont accès à l'information et aux systèmes de la Société. En outre, la Société doit créer une culture dans laquelle tous les individus prennent des décisions efficaces fondées sur le risque et protègent l'information confidentielle utilisée dans l'ensemble de la Société contre toute compromission. Les exigences nécessaires pour former les employés et les tiers concernés à la sécurité de l'information sont énumérées ci-dessous.

a. Concevoir un programme de formation obligatoire de sensibilisation à la sécurité générale destiné à tous les membres du personnel.
b. Concevoir le programme pour fournir à des groupes d'utilisateurs spécifiques du matériel de formation en fonction de leurs rôles et responsabilités au sein de la Société.

c. S'assurer que chaque module de formation comporte une évaluation avec une note minimale pour la réussite.
d. Appliquer des sanctions aux individus si la formation n'est pas achevée dans un délai déterminé, par exemple en limitant leurs droits d'accès à certaines ressources et en ne leur permettant de retrouver l'accès qu'après avoir réussi la formation.
e. Organiser des exercices pratiques, tels que des campagnes d'hameçonnage et des exercices sur table, pour simuler des cyberattaques réelles et renforcer les enseignements tirés du matériel de formation.
f. Établir et institutionnaliser le contact avec des groupes et associations sélectionnés au sein de la communauté de la sécurité afin de faciliter l'éducation et la formation continues en matière de sécurité pour le personnel de la Société, et de recueillir de l'information et du matériel de formation supplémentaires sur les tendances pertinentes en matière de sécurité dans l'industrie.
g. Mettre à jour et adapter périodiquement le matériel de formation pour s'assurer qu'il reste actuel et pertinent.

2.5. Exigences relatives à la gestion des changements

Les changements apportés aux applications d'entreprise, aux systèmes d'information et aux périphériques réseau doivent être testés, examinés et appliqués à l'aide d'un processus de gestion des changements. L'objectif de la gestion des changements est de garantir que les changements sont appliqués correctement, de manière cohérente et traçable, sans compromettre la sécurité de l'environnement technologique de la Société. Les exigences nécessaires à la gestion des changements dans l'infrastructure de la Société afin de garantir que tous les changements sont documentés et que leur impact est évalué avant d'être approuvés sont énumérées ci-dessous.

a. Créer un comité consultatif des changements (CAB ou CCC) chargé de gérer les politiques générales de gestion des changements ainsi que d'examiner et d'autoriser toutes les demandes de changement lors de réunions récurrentes.
b. Identifier, enregistrer et classer les changements proposés aux systèmes d'information.
c. Établir des procédures spécifiques pour le contrôle, l'autorisation et la documentation appropriés des changements d'urgence.
d. Évaluer le risque d'affaires, le risque opérationnel et le risque de sécurité de l'information avant l'approbation d'un changement.
e. Exiger un plan de repli documenté pour chaque changement comme condition préalable à l'examen par le CCC.
f. Tester, valider et documenter les changements apportés aux systèmes d'information dans un environnement de test, le cas échéant.
g. Mettre en œuvre uniquement les changements officiellement approuvés dans l'environnement de production, en comparant les effets mesurés du changement avec les effets souhaités. Chaque changement doit recevoir l'approbation d'affaires et/ou technique d'un approbateur désigné avant sa mise en œuvre.

h. Effectuer une révision après le changement et distribuer le retour d'information à toutes les parties impliquées dans le changement pour encourager et permettre des améliorations futures.

2.6. Exigences relatives à la gestion des configurations

La Société doit établir, mettre en œuvre et gérer activement les composants du système d'information sur la configuration de la sécurité à l'aide de processus rigoureux de gestion des configurations et de contrôle des changements afin d'empêcher les attaquants d'exploiter les services et les paramètres vulnérables. La gestion des configurations permet également de s'assurer que tous les utilisateurs exécutent les paramètres de sécurité approuvés sur leurs appareils. Les exigences nécessaires au maintien de l'intégrité du matériel, des logiciels, des micrologiciels et de la documentation liée aux configurations des actifs TI qui soutiennent l'environnement technologique de la Société sont énumérées ci-dessous.

a. Définir et mettre en œuvre des normes de configuration de base fondées sur les lignes directrices des fournisseurs et de l'industrie et appliquer le principe de la moindre fonctionnalité chaque fois que possible en configurant le système pour n'autoriser que les capacités requises et approuvées.
b. S'assurer que tous les changements apportés aux normes de configuration de base passent par le processus de gestion des changements et sont formellement approuvés.
c. Privilégier l'utilisation d'outils centralisés et automatisés pour pousser les nouvelles configurations vers les dispositifs autorisés appropriés.
d. Gérer le suivi des configurations de manière centralisée, dans la mesure du possible, pour appliquer, maintenir à jour et vérifier le déploiement des normes de configuration de base.
e. Surveiller les journaux du système et recevoir des alertes lorsque des modifications non autorisées des paramètres de configuration sont détectées afin de permettre une réponse automatisée qui peut restaurer les paramètres de configuration établis ou arrêter un système dans les cas extrêmes.

2.7. Exigences relatives à la sécurité infonuagique

La Société doit établir des exigences pour incorporer des contrôles de sécurité dans le cycle de vie de tout service infonuagique afin de se prémunir contre le risque et les menaces qui y sont associés. Ces contrôles de sécurité doivent être identifiés comme faisant partie des exigences d'affaires pour l'acquisition de nouveaux services infonuagiques et/ou l'amélioration des services infonuagiques existants, quel que soit le type de service ou le modèle de déploiement utilisé. Les exigences nécessaires pour identifier et gérer le risque lié à la sécurité de l'information à chaque étape des relations avec les fournisseurs de services infonuagiques sont énumérées ci-dessous.

a. Définir et documenter une politique d'entreprise pour l'achat et l'utilisation de services infonuagiques, approuvée par la haute direction, diffusée et appliquée dans toute la Société.
b. Évaluer le risque potentiel de sécurité avant d'acquérir ou d'utiliser des services infonuagiques. Répéter régulièrement l'évaluation pour garantir sa pertinence.

c. S’engager uniquement qu'avec des fournisseurs de services infonuagiques dignes de confiance en vérifiant qu’ils détiennent au moins une attestation de certification de sécurité reconnue ou qu’ils sont en mesure de répondre aux exigences de sécurité de la Société.
d. S’assurer que chaque service infonuagique est soutenu par une entente assortie de niveaux de service spécifiques afin de faire respecter contractuellement les exigences de sécurité de la Société.
e. S'assurer que toutes les ententes sont examinées par les services juridiques de la Société, les TI et les affaires, et qu'ils sont soumis au processus d'approvisionnement de la Société.
f. Exiger du fournisseur de services infonuagiques qu'il réponde aux exigences de disponibilité de la Société en fournissant une assistance dédiée en cas d'incident de sécurité ou d'action en justice impliquant l’information de l’entreprise.
g. Exiger du fournisseur de services infonuagiques qu'il démontre sa capacité à protéger adéquatement l’information de la Société en :
    - Fournissant la preuve de sa conformité aux normes de sécurité reconnues
    - Effectuant des évaluations du risque, et
    - Faisant régulièrement auditer son environnement technologique par un tiers indépendant.
h. Définir et documenter un processus de résiliation des services infonuagiques qui permette à la Société de récupérer ses données, et de nettoyer par effacement les données de la Société de l'environnement du fournisseur de services infonuagiques d'une manière contrôlée.
i. S'assurer que la Société obtient une description claire des politiques et procédures de bris de confidentialité du fournisseur de services infonuagiques, des processus de gestion des vulnérabilités et des correctifs, ainsi que des emplacements géographiques où l’information est stockée ou traitée.
j. S'assurer que les services infonuagiques sont soumis aux mêmes normes de sécurité que les services hébergés en interne tout en tenant compte des spécificités de l’infonuagique et du partage des responsabilités avec les fournisseurs de services infonuagiques.

2.8. Exigences relatives à la cryptographie

La Société doit utiliser des contrôles cryptographiques pour assurer la confidentialité, l'intégrité, l'authentification et la non-répudiation de l’information. Les exigences nécessaires à la protection cryptographique pour sauvegarder les actifs informationnels de la Société sont énumérées ci-dessous.

a. Chiffrer les données relatives à l’information confidentielle ou critique tant lors de leur transmission que lors de leur stockage.
b. N'utiliser que les algorithmes et protocoles cryptographiques recommandés par l'industrie lors de la mise en œuvre des contrôles cryptographiques.
c. Protéger tous les mots de passe et autres vérificateurs d'authentification par un hachage unidirectionnel avant leur transmission et leur stockage.
d. Chiffrer les données stockées sur les actifs fournis pour une utilisation à distance, y compris les ordinateurs portables et autres dispositifs mobiles.
e. N'utiliser que des composants cryptographiques qui ont été testés et validés de manière adéquate par rapport à des normes établies.

f. Surveiller l'évolution du portefeuille de risque associé à tout contrôle cryptographique.
g. Fournir des procédures opérationnelles standard et des lignes directrices pour tous les aspects du chiffrement et de la gestion, des opérations et de la maintenance des clés.
h. Exiger des tiers qu'ils respectent les exigences de validation cryptographique dans l'ensemble de leurs systèmes.
i. Gérer les clés cryptographiques en toute sécurité dans tous les états et toutes les phases, de la génération à la destruction, afin de réduire au minimum le risque de compromission.

2.9. Exigences relatives à la sécurité des points de terminaison

Étant donné que les points de terminaison sont capables de traiter, de stocker ou de communiquer de l'information confidentielle, la Société doit s'assurer qu'ils sont protégés de manière appropriée, quel que soit leur type ou leur emplacement. Les exigences nécessaires à la sécurité des points de terminaison sont énumérées ci-dessous.

a. Établir des exigences de sécurité pour la protection des points de terminaison utilisés pour accéder aux informations et aux systèmes d'information de l'entreprise, qui couvrent l'ensemble de leur cycle de vie.
b. S'assurer que les points de terminaisons gérés par la Société sont protégés par des contrôles de sécurité adéquats, y compris, mais sans s'y limiter, des normes de configuration de base, des vérifications de conformité avant la connexion aux systèmes et réseaux de l'entreprise, la cryptographie, les restrictions d'installation de logiciels, les technologies de protection des points de terminaison et antimalware.
c. Mettre en œuvre des contrôles pour restreindre l'utilisation du stockage externe (par exemple, sur des dispositifs de stockage portables, des supports amovibles, des services de stockage infonuagiques).
d. Restreindre la connexion des points de terminaison qui ne sont pas gérés par la Société aux systèmes et réseaux de l'entreprise.
e. S'assurer que tous les dispositifs IoT (par exemple, téléviseur intelligent, capteur d'humidité) utilisés par la Société sont identifiés et gérés de manière appropriée afin de ne pas introduire involontairement un nouveau risque.

2.10. Exigences relatives à la gestion des identités et des accès

La Société doit s'assurer que l'accès à ses actifs informationnels ainsi qu'aux actifs qui les soutiennent est limité aux utilisateurs, processus et dispositifs autorisés, et que l'accès aux ressources est sécurisé et autorisé sur la base de la séparation des tâches et du principe du moindre privilège. Les exigences nécessaires pour assurer une gestion adéquate des identités et du contrôle d'accès sont énumérées ci-dessous.

a. S'assurer que tous les systèmes d'information identifient et authentifient de manière unique les utilisateurs, y compris les utilisateurs externes tels que les clients et les courtiers, ou les processus agissant au nom des utilisateurs dont les accès ont été approuvés.
b. Définir des types de compte avec des conventions de dénomination établies, des hauts privilèges, des restrictions et la propriété de chaque type de compte.

c. Appliquer des contrôles de mot de passe tels que des exigences de complexité, de durée de vie, de partage et de désactivation de compte pour tous les types de compte, tout en augmentant la complexité des mots de passe pour les comptes à haut privilège.
d. Protéger tous les mots de passe par chiffrement lorsqu'ils sont stockés ou transmis sur des réseaux.
e. Exiger une authentification multifactorielle dans les situations à haut risque, telles que l'utilisation de hauts privilèges, l'accès à de l'information confidentielle, la connexion à des actifs informationnels critiques et l'accès à distance aux services de la Société.
f. Établir des processus d'approvisionnement et de dé-provisionnement des comptes en utilisant des mécanismes automatisés, dans la mesure du possible.
g. Établir et suivre un processus pour octroyer et révoquer les accès tout en conservant toutes les demandes d'accès dans un référentiel pour référence ultérieure.
h. Mettre en œuvre des contrôles d'accès basés sur les rôles en s'assurant que la conception des rôles des utilisateurs respecte le concept de séparation des tâches et que le principe du moindre privilège est appliqué pour les autorisations d'accès.
i. Attribuer des hauts privilèges en fonction des besoins ou, si possible, en fonction des événements, pour des applications et des tâches spécifiques, uniquement pendant le moment où elles sont nécessaires.
j. Revoir les rôles des utilisateurs, les droits et les hauts privilèges attribués à chaque rôle de façon régulière et après des changements majeurs.

2.11. Exigences relatives à la sécurité des réseaux et des communications

La Société doit éviter les connexions non autorisées et non sécurisées aux services du réseau, en particulier pour les connexions à des applications commerciales critiques ou provenant d'utilisateurs situés dans des lieux à haut risque. La Société devrait également envisager des conceptions de réseau qui compartimentent le risque interne et externe en configurant une segmentation correcte et en mettant en œuvre des contrôles adaptés au risque inhérent à ses services de base. Les exigences nécessaires pour établir des réseaux fiables et résilients qui empêchent les accès et les connexions non autorisés dans l'environnement technologique de la Société sont énumérées ci-dessous.

a. Définir et communiquer les directives d'utilisation du réseau concernant l'utilisation des réseaux et des services de réseau.
b. Maintenir et réviser la documentation relative au réseau qui comprend les diagrammes, les configurations et les contrôles de sécurité mis en œuvre.
c. Maintenir un inventaire à jour de toutes les limites du réseau de la Société.
d. Protéger les adresses réseau des composants des systèmes d'information contre toute découverte grâce à des outils et techniques communs utilisés pour identifier les dispositifs sur les réseaux.
e. Mettre en œuvre plus d'un type de système de protection des limites pour gérer les communications du réseau depuis et vers les réseaux externes.
f. Définir et réviser la configuration des dispositifs de réseau en suivant les normes de l'industrie afin de s'assurer que seuls les utilisateurs autorisés peuvent accéder aux systèmes d'information sur le réseau.

g. Segmenter les réseaux en utilisant une approche à plusieurs niveaux qui tient compte des niveaux de classification de l'information stockée dans les différentes zones de ces réseaux.
h. Établir un réseau distinct pour les dispositifs personnels ou non fiables.
i. Fournir aux utilisateurs un accès uniquement au réseau et aux services du réseau qu'ils ont été spécifiquement autorisés à utiliser.
j. N'autoriser que les dispositifs autorisés à se connecter au réseau de la Société et vérifier qu'avant de se voir octroyer l'accès, les dispositifs sont conformes aux exigences minimales de configuration.
k. Surveiller les communications aux frontières externes et aux frontières internes clés et filtrer le trafic réseau pour bloquer toute communication non autorisée.
l. Limiter l'accès aux services infonuagiques non autorisés.
m. N'utiliser que les outils ou les passerelles d'entreprise autorisés pour communiquer par courrier électronique avec les utilisateurs ou les clients, y compris les envois en masse.
n. Traiter tous les courriels reçus ou envoyés par le biais d'un système anti-spam afin de bloquer toute communication frauduleuse.
o. Analyser régulièrement tous les systèmes du réseau afin d'identifier toutes les vulnérabilités potentielles.

2.12. Exigences relatives à la sécurité des opérations

La Société doit s'assurer que des contrôles de sécurité de l'information adéquats sont intégrés aux opérations informatiques afin de maintenir la fiabilité et le bon fonctionnement des installations de traitement de l'information. Les exigences nécessaires pour établir des contrôles de sécurité opérationnelle afin de maintenir et de renforcer la sécurité dans les opérations quotidiennes sont énumérées ci-dessous.

a. Créer un centre d'opérations de sécurité (SOC), ou une fonction similaire, dont la mission et les responsabilités sont définies et qui est doté de personnel qualifié en matière de cybersécurité.
b. Documenter et maintenir des procédures d'exploitation, de construction et de récupération complètes et suffisantes pour les systèmes de production, et les mettre à la disposition de tout le personnel autorisé.
c. Surveiller, ajuster et examiner régulièrement l'utilisation des ressources sur les systèmes de production afin d'identifier les besoins actuels et futurs en matière de capacité.
d. Séparer les environnements de développement et de test de l'environnement de production afin de réduire le risque d'accès ou de modifications non autorisés de l'environnement de production.

2.13. Exigences relatives à la sécurité physique et environnementale

La sécurité physique et environnementale englobe un ensemble de menaces, de vulnérabilités et de contre-mesures différent de celui de la sécurité informatique et de l'information. L'objectif est de maintenir un environnement physique sûr en empêchant les accès non autorisés, les dommages et les interférences aux installations et aux systèmes d'information. Les exigences nécessaires pour protéger

les systèmes d'information et l'infrastructure de soutien de la Société contre les menaces associées à leur environnement physique sont énumérées ci-dessous.

a. Documenter et maintenir les processus de protection physique et environnementale définissant les rôles et les responsabilités, la coordination entre les entités organisationnelles et les contrôles de protection associés.
b. Élaborer et tenir à jour un registre détaillant les accès autorisés aux installations par les personnes en fonction de leur poste ou de leur rôle.
c. Déterminer les exigences de sécurité physique des installations en fonction des résultats des évaluations du risque pour les systèmes qu'elles contiennent et des considérations géographiques.
d. Tenir un inventaire de tous les dispositifs d'accès physique aux points d'accès critiques, tels que les clés et les cartes d'accès, et enquêter régulièrement sur toute anomalie.
e. Tenir et examiner les registres d'accès des visiteurs et exiger que les visiteurs soient escortés par des personnes possédant les accréditations appropriées pour accéder aux installations où est stockée de l'information confidentielle.
f. Contrôler l'accès physique aux installations en utilisant des enregistrements vidéo de surveillance des points d'accès critiques et en tenant et en examinant les registres d'accès physique.
g. Mettre en place des contrôles de sécurité pour protéger l'équipement électrique de la Société, pour maintenir les niveaux de température et d'humidité dans les installations où résident les systèmes d'information et pour protéger ces installations contre les incendies et les dégâts des eaux.
h. Mettre en place des contrôles d'urgence suffisants en cas de panne ou de perturbation de l'alimentation électrique pour assurer la continuité des activités.
i. Coordonner l'enquête et l'examen de la réponse aux incidents en cas de violations apparentes de la sécurité ou d'activités d'accès physique suspectes.

2.14. Exigences relatives à la gestion des sauvegardes

La Société doit sauvegarder régulièrement les informations essentielles et stocker les sauvegardes en toute sécurité pour se protéger contre la perte ou la corruption des données. Les exigences nécessaires pour garantir que la Société puisse restaurer l'information dans des délais critiques en cas d'urgence sont énumérées ci-dessous.

a. Établir, documenter et maintenir des procédures de sauvegarde qui décrivent les exigences opérationnelles et les méthodes d'exécution et de vérification des sauvegardes. Les procédures doivent traiter des cycles de sauvegarde et des mesures en place pour protéger les données de sauvegarde.
b. Effectuer des sauvegardes de la documentation du système d'information, des informations essentielles et des logiciels sur une base régulière, selon un cycle temporel défini.
c. Protéger les sauvegardes par des contrôles de sécurité physique ou par chiffrement lorsqu'elles sont stockées, transférées sur des supports de sauvegarde ou déplacées sur le réseau.

d. Assurer la disponibilité des sauvegardes en les transférant vers des sites de stockage alternatifs, soit par voie électronique, soit par l'envoi physique de supports de stockage.
e. S'assurer que les informations ou les logiciels essentiels peuvent être restaurés dans les délais critiques en cas d'urgence, tels que déterminés par les plans de continuité des activités et les dispositions connexes, y compris les exigences réglementaires et contractuelles.
f. Tester régulièrement un échantillon représentatif de tous les types de sauvegardes pour vérifier la fiabilité des supports et l'intégrité des informations.

2.15. Exigences relatives au cycle de vie du développement logiciel

La Compagnie doit concevoir, développer, tester, mettre en œuvre et maintenir les logiciels conformément aux meilleures pratiques de l'industrie, tout en intégrant la sécurité de l'information à chaque étape du cycle de vie de leur développement. Les exigences nécessaires à appliquer tout au long du cycle de vie du développement logiciel de la Compagnie sont énumérées ci-dessous.

a. S'assurer que la sécurité des logiciels est prise en compte au sein de la Société en établissant une feuille de route stratégique pour la sécurité des logiciels, en identifiant les facteurs de gouvernance et de conformité pertinents et en formant les équipes de développement.
b. Définir les spécifications des exigences pour le cycle de vie du développement logiciel sécurisé.
c. Gérer tous les codes dans un emplacement sécurisé, tel qu'un référentiel de codes, qui est protégé par un contrôle d'accès.
d. S'assurer que le logiciel est développé dans un environnement de développement sécurisé, séparé de l'environnement de production.
e. Effectuer des contrôles réguliers de la conformité des logiciels développés en interne et par des tiers par rapport aux exigences de sécurité définies.
f. S'assurer que les codes sont revus par des personnes distinctes des auteurs du code original.
g. Effectuer des évaluations de sécurité périodiques pour découvrir les failles et les vulnérabilités du code source et veiller à y remédier avant le déploiement dans l'environnement de production.
h. S'assurer que toutes les modifications proposées et le déploiement dans l'environnement de production suivent un processus formel de demande de modification et d'approbation, y compris des tests dans un environnement d'essai.

2.16. Exigences relatives à la sécurité des applications

Les exigences nécessaires à l'intégration de contrôles de sécurité dans les applications d'entreprise afin de protéger la confidentialité, l'intégrité et la disponibilité de l'information lorsqu'elle est entrée, traitée et sortie de ces applications sont énumérées ci-dessous.

a. Développer, maintenir et réviser régulièrement un inventaire de toutes les applications autorisées dans la Société. Dans la mesure du possible, lier l'inventaire des applications à l'inventaire des actifs matériels.
b. Protéger les applications et les données en assurant un contrôle d'accès adéquat, la journalisation et la surveillance de l'activité des utilisateurs, la ségrégation des systèmes et la gestion des vulnérabilités.

c. Maintenir les applications et les systèmes d'exploitation en s'assurant qu'ils exécutent les mises à jour de sécurité les plus récentes fournies par les fournisseurs et en appliquant les normes de configuration de sécurité documentées.
d. Déclasser les applications à la fin de leur vie en suivant une procédure documentée pour s'assurer que des actions non autorisées ne sont pas commises.

3. Écarts et exceptions

Dans les cas où cette directive n'est pas respectée, une demande de dérogation doit être remplie en suivant le processus de dérogation au cadre normatif de sécurité de l'information.

Veuillez contacter l'équipe de sécurité de l'information < *DemandesSecuriteSI@ia.ca* > pour obtenir plus d'informations sur ce processus ou sur la directive, le cas échéant.